

NETWORK VULNERABILITY IDENTIFICATION FOR KAPASA MAKASA UNIVERSITY USING OPEN-SOURCE TOOLS

From The Cybersecurity Department

Systems Vulnerability Assessment Team

Prepared for

Mr. Paul M. Mutunda

Technical Report By – James Soko (20231392)

Table of Contents

1. Introduction 2

1.1. Background *2*

1.2. Scope *2*

1.3. Objectives *2*

2. Methodology 3

2.1. Tool Used *3*

2.2. Data Collection *4*

2.3. Analysis *4*

***3.* Findings** 5

4. Mitigation and Recommendation 9

5. Hypothesis 9

6. Conclusion 10

References 10

List of Figures

Figure 1: CVSS scanned by the Nmap vuln script and summarized by ChatGPT 4

Figure 2: Web related vulnerabilities scanned with ZAP 5

Figure 3: DH vulnerability scanned by Nmap vuln scripts 5

Figure 4: Slowloris DoS attack vulnerability scanned by Nmap vuln scripts 6

Figure 5: SYN Flood DDoS attack using hping3 6

Figure 6: Slowloris DoS Attack 6

Figure 7: Domain Controllers retrieved using DNS query tools 7

Figure 8: OS and Ports scanned by Nmap 7

Figure 9: Subnets scanned by Nmap 8

Figure 10: External JavaScript (Google Analytics) Loaded Without Integrity Check (ZAP) 8

Figure 11: Mitigating the JavaScript (Google Analytics) Loaded with integrity check 9

1. Introduction

Vulnerability Assessment is the process of pinpointing, computing and ranking the vulnerabilities in the system. In this process, such as operating systems, application software and network are scanned in order to identify the occurrence of well-known and unknown vulnerabilities. These vulnerabilities are occurring due to inappropriate software design, insecure authentication or as a result of misconfiguration (Umrao, et al., 2016).

1.1. Background

Vulnerability management involves the identification, classification, remediation, and mitigation of vulnerabilities which are found in web applications, server and workstation software, as well as programs and applications (Foreman, 2019).

1.2. Scope

This report focuses on the vulnerability scanning and assessment of application software, network infrastructure, server computers, and operating systems using open-source tools. It also explores unauthenticated techniques to identify security risks.

1.3. Objectives

1.3.1. Main

1.3.1.1. Scanning for vulnerabilities in an Application Software.
1.3.1.2. Scanning for vulnerabilities in a Network Infrastructure.
1.3.1.3. Scanning for vulnerabilities in a Server Computer.
1.3.1.4. Scanning for vulnerabilities in an Operating System (OS).

1.3.2. Specific

1.3.2.1. Performing SYN Flood DDoS Attack.
1.3.2.2. Collecting details about a network such as IP address and subnets.
1.3.2.3. Port scanning and Banner Grabbing.
1.3.2.4. Conducting an unauthenticated scan.
1.3.2.5. Dynamic application security testing
1.3.2.6. Performing code review
1.3.2.7. OS fingerprinting.

2. Methodology

This section outlines the approach taken to assess vulnerabilities in application software, network infrastructure, server computers, and operating systems. The methodology consists of scanning, analysis, and attack simulation using open-source tools.

2.1. Tool Used

2.1.1. OWASP Zed Attack Proxy (ZAP)

Is a powerful open-source tool designed to enhance the security of web applications by identifying vulnerabilities and providing actionable insights for mitigation. Its features include a built-in vulnerability scanner for identifying vulnerabilities like insecure configurations, missing security headers, and common web application flaws. (Bisht, 2015).

2.1.2. Network Mapper (Nmap)

Allows network admins to find which devices are running on their network, discover open ports and services, and detect vulnerabilities (Shivanandhan, 2020).

2.1.3. Hping3

Is a network tool able to send custom ICMP/UDP/TCP packets and to display target replies like ping does with ICMP replies (Panda & Ramamoorthy, 2023).

2.1.4. Slowloris

Is a well-known application-layer Denial of Service (DoS) attack that is challenging to detect due to its low-rate nature, allowing it to blend with legitimate traffic and remain unnoticed (Gavrić & Bhandari, 2024).

2.1.5. Artificial Intelligence (AI) (ChatGPT)

AI is technology that enables computers and machines to simulate human learning, comprehension, problem solving, decision making, creativity and autonomy (Stryker, 2024).

ChatGPT is a chatbot that was developed by the artificial intelligence research company OpenAI. It has a number of different functions such as debugging and fixing code, creating text summaries, making recommendations, classifying things, and explaining what something does, such as a code block (Kramer, 2022).

2.2. Data Collection

The data collection involved automated vulnerability scanning using ZAP (see Figure 2) and Nmap (see Figure 3 and 4) to identify security flaws. Active penetration testing was conducted with Hping3 (see Figure 5) and Slowloris (see Figure 6) to assess network and server resilience. Manual analysis and ChatGPT (see Figure 1) assisted interpretation helped refine findings. The results were validated using industry standards like OWASP Top 10 and CVSS for accuracy and severity assessment.

2.3. Analysis

The vulnerability assessment revealed critical security flaws in the FTP (see Figure 3) and HTTP (see Figure 4) services, which could be exploited by attackers to compromise system integrity and availability. The findings are summarized in the table below:

Port	Service	Vulnerability Detected	Risk Level	Description & Impact
21	FTP	**Anonymous Diffie-Hellman (DH) Key Exchange Vulnerability**	🔴 **High**	Allows **Man-in-the-Middle (MITM) attacks**, compromising confidentiality & integrity of data over TLS.
80	HTTP	**Slowloris DoS Attack (CVE-2007-6750)**	🟠 **Medium**	Attack exhausts server resources by holding HTTP connections open indefinitely, leading to **Denial of Service (DoS)**.

Figure 1: CVSS scanned by the Nmap vuln script and summarized by ChatGPT

3. Findings

3.1. Application Software, Network Infrastructure, Server Computer and Operating System (OS) Vulnerabilities

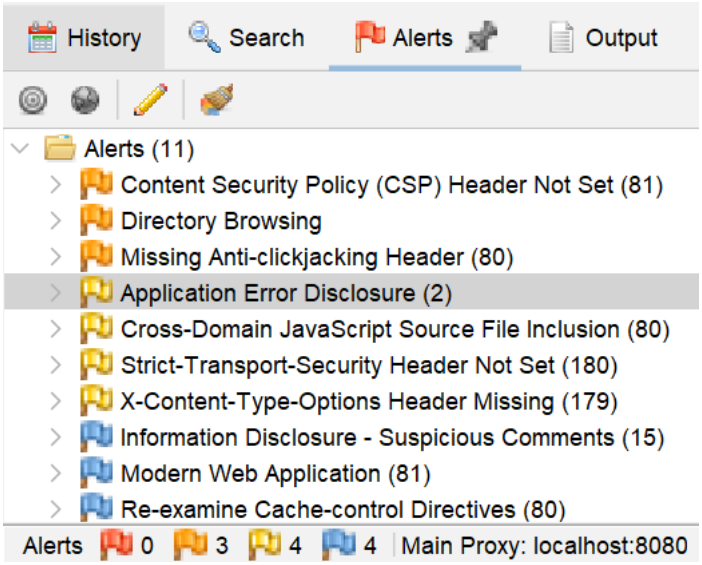


Figure 2: Web related vulnerabilities scanned with ZAP

```
rDNS record for 41.63.0.22: webservices.zamren.zm
Not shown: 988 closed tcp ports (reset)
PORT     STATE    SERVICE
21/tcp   open     ftp
| ssl-dh-params:
|   VULNERABLE:
|   Anonymous Diffie-Hellman Key Exchange MitM Vulnerability
|     State: VULNERABLE
|       Transport Layer Security (TLS) services that use anonymous
|       Diffie-Hellman key exchange only provide protection against passive
|       eavesdropping, and are vulnerable to active man-in-the-middle attacks
|       which could completely compromise the confidentiality and integrity
|       of any data exchanged over the resulting session.
|     Check results:
|       ANONYMOUS DH GROUP 1
|             Cipher Suite: TLS_DH_anon_WITH_AES_256_GCM_SHA384
|             Modulus Type: Non-safe prime
|             Modulus Source: RFC5114/2048-bit DSA group with 256-bit prime order subgroup
|             Modulus Length: 2048
|             Generator Length: 2048
|             Public Key Length: 2048
|     References:
|_      https://www.ietf.org/rfc/rfc2246.txt
22/tcp   open     ssh
25/tcp   filtered smtp
53/tcp   open     domain
80/tcp   open     http
```

Figure 3: DH vulnerability scanned by Nmap vuln scripts

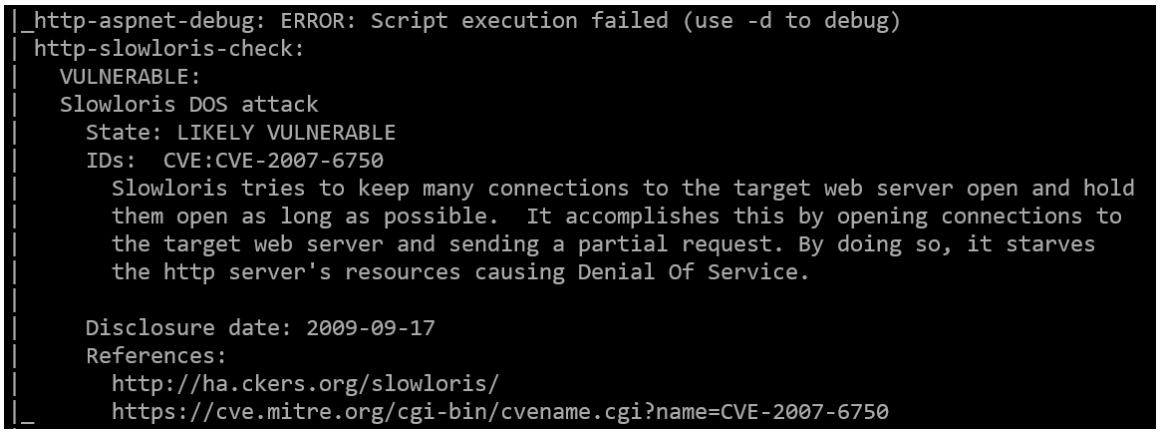


Figure 4: Slowloris DoS attack vulnerability scanned by Nmap vuln scripts

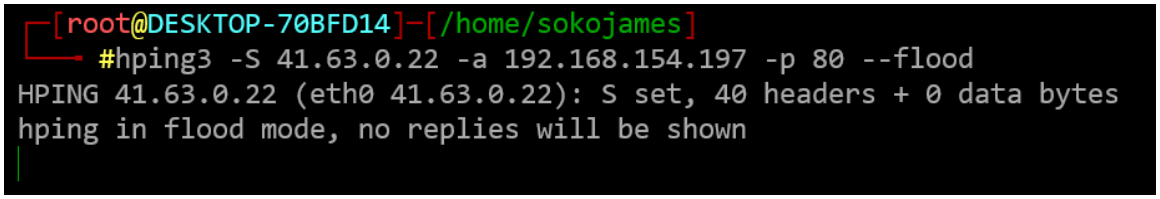


Figure 5: SYN Flood DDoS attack using hping3

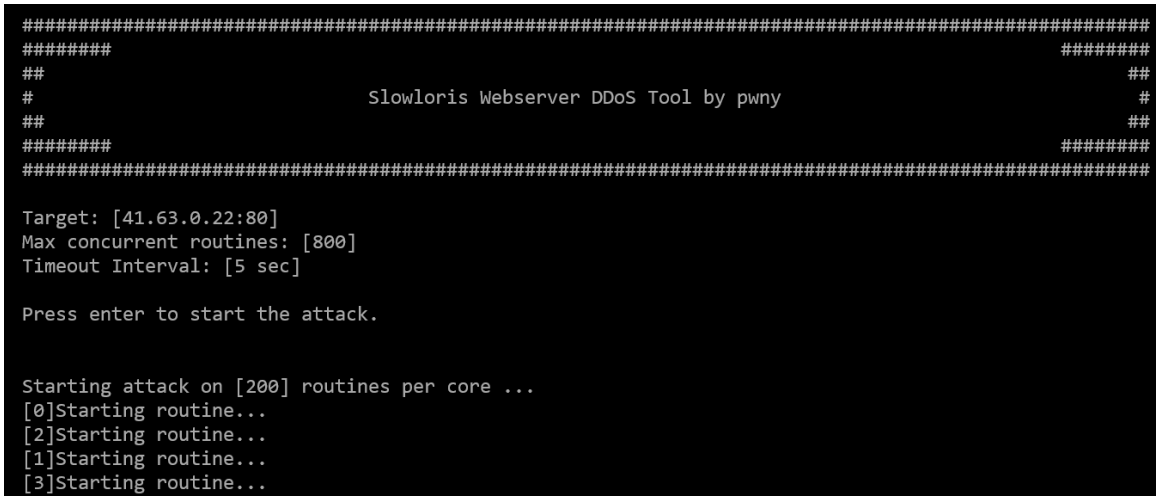


Figure 6: Slowloris DoS Attack

3.2. KMU Website and Domain Controllers with Their Respective IPs



Figure 7: Domain Controllers retrieved using DNS query tools

3.3. Operating Systems (OS) and Port Status

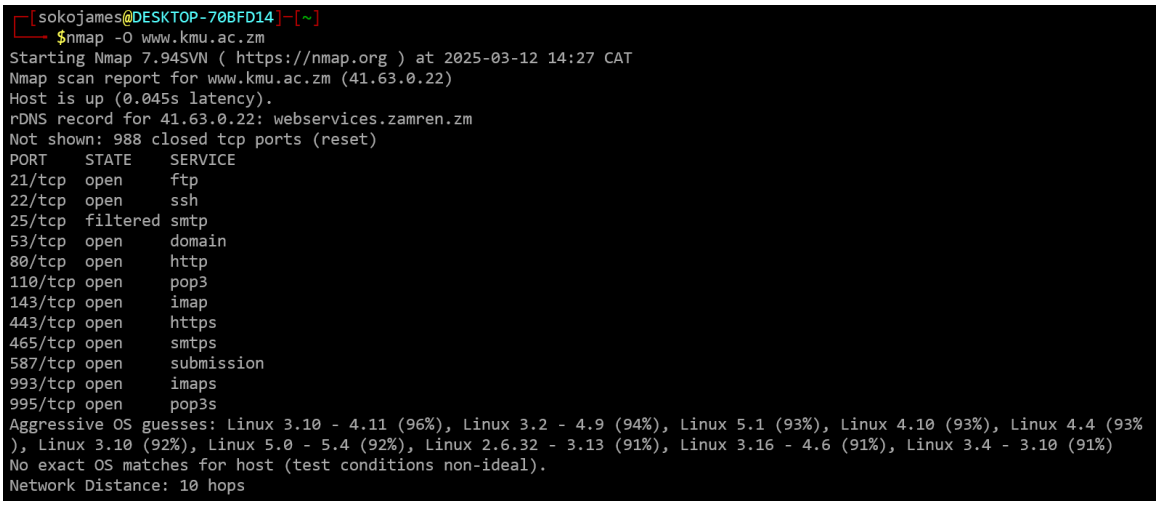


Figure 8: OS and Ports scanned by Nmap

3.4. Subnets and Their IP Addresses

```
┌──[root@DESKTOP-70BFD14]─[/home/sokojames/Desktop/slowloris]
└─ #nmap -sP 41.63.0.0/24
Starting Nmap 7.94SVN ( https://nmap.org ) at 2025-03-13 02:27 CAT
Nmap scan report for 41.63.0.1
Host is up (0.049s latency).
Nmap scan report for redsun.zamren.zm (41.63.0.3)
Host is up (0.059s latency).
Nmap scan report for 41.63.0.4
Host is up (0.061s latency).
Nmap scan report for mtr4.zamren.zm (41.63.0.5)
Host is up (0.070s latency).
Nmap scan report for ns3.zamren.zm (41.63.0.6)
Host is up (0.061s latency).
Nmap scan report for 41.63.0.13
Host is up (0.074s latency).
Nmap scan report for 41.63.0.19
Host is up (0.068s latency).
Nmap scan report for 41.63.0.20
Host is up (0.059s latency).
Nmap scan report for webservices.zamren.zm (41.63.0.22)
Host is up (0.047s latency).
Nmap scan report for mailrelay.zamren.zm (41.63.0.23)
Host is up (0.082s latency).
Nmap scan report for mtr2.zamren.zm (41.63.0.25)
Host is up (0.050s latency).
Nmap scan report for mtr3.zamren.zm (41.63.0.28)
```

Figure 9: Subnets scanned by Nmap

3.5. Code Review

```
<script async src="https://www.googletagmanager.com/gtag/js?id=G-01BY8NDB9F"></script>
<script>
  window.dataLayer = window.dataLayer || [];
  function gtag(){dataLayer.push(arguments);}
  gtag('js', new Date());

  gtag('config', 'G-01BY8NDB9F');
</script>
```

Figure 10: External JavaScript (Google Analytics) Loaded Without Integrity Check (ZAP)

4. Mitigation and Recommendation

To mitigate the risk of loading external JavaScript (Google Analytics) without an integrity check (see Figure 10), implement Sub resource Integrity (SRI) by adding the integrity attribute with a cryptographic hash. This ensures that the script has not been tampered with. Additionally, use crossorigin="anonymous" to prevent data leaks.

```
<script async src="https://www.googletagmanager.com/gtag/js?id=G-01BY8NDB9F"
        integrity="sha384-BASE64HASH"
        crossorigin="anonymous"></script>
```

Figure 11: Mitigating the JavaScript (Google Analytics) Loaded with integrity check

Below are some of the ways that can be used to mitigate the vulnerabilities shown in Figure 2 – 4.

Threat	**Recommendation**
Slowloris DoS Attack	Limit connections, reduce timeouts, use WAF and enable SYN cookies
ADH Key Exchange	Disable ADH ciphers, use DHE/ECDHE, and enforce TLS 1.2+
Content Security Policy (CSP)	Set strict CSP headers, avoid unsafe-inline, and test with Report-Only mode
Anti-Clickjacking	Use X-Frame-Options: DENY, frame-ancestors 'none', and JavaScript frame-breaking

5. Hypothesis

Open-source vulnerability scanning tools can effectively identify security weaknesses in application software, network infrastructure, server computers, and operating systems. If these vulnerabilities are detected and mitigated using recommended security measures, then the overall resilience of the system against cyber threats will improve Kapasa Makasa University's digital assets.

6. Conclusion

The technical report confirms that vulnerability assessment (VA) and vulnerability management (VM) are crucial for identifying and mitigating security risks in applications, networks, servers, and operating systems. Open-source tools effectively detect these vulnerabilities, but continuous monitoring, timely patching, and proactive security measures are essential to maintaining a robust cybersecurity posture (Foreman, 2019).

References

Bisht, R., 2015. *What is OWASP Zed Attack Proxy (ZAP)?.* [Online]
Available at: https://www.infosectrain.com/blog/what-is-owasp-zed-attack-proxy-zap/

Foreman, S. J., 2019. *Vulnerability Management: A Comprehensive Guide to Managing Cybersecurity Risks.* Hoboken, NJ: Wiley.

Gavrić, N. & Bhandari, G., 2024. *ntroducing the Slowloris E-DoS Attack: a Threat Arising From Vulnerabilities in the FTP and SSH Protocols.* s.l.:ResearchGate.

Kramer, Z., 2022. *What Is Chat GPT And How Does It Work?.* [Online]
Available at: https://www.freshered.com/what-is-chat-gpt-and-how-does-it-work/

Panda, M. K. & Ramamoorthy, H., 2023. *Traffic Generator/DDoS Tool.* s.l.:s.n.

Shivanandhan, M., 2020. *What is Nmap and How to Use it – A Tutorial for the Greatest Scanning Tool of All Time.* [Online]
Available at: https://www.freecodecamp.org/news/what-is-nmap-and-how-to-use-it-a-tutorial-for-the-greatest-scanning-tool-of-all-time/

Stryker, C., 2024. *What is artificial intelligence (AI)?.* [Online]
Available at: https://www.ibm.com/think/topics/artificial-intelligence

Umrao, S., Kaur, M. & Gupta, G. K., 2016. *VULNERABILITY ASSESSMENT AND PENETRATION TESTING*, VII(3), p. 2.